

PROSPECTUS

Toward Open-Source, Passwordless Document Encryption

Isaac Teuscher
April 16, 2025

I. NATURE OF THE PROBLEM

Electronic documents containing highly sensitive data are used across nearly every industry and profession. Examples include health records, legal counsel, financial data, trade secrets, employment contracts, and others. These sensitive documents are often stored and shared using cloud services like managed file transfer (MFT) applications. Users trust these platforms to keep their data secure.

However, in recent years, several large MFT applications experienced mass exploit events that compromised millions of confidential documents, including personal health data, government records, and legal files [5, 11]. The largest incident resulted in the exposure of 95,788,491 individuals' personal information [25].

Though MFTs encrypt files “at rest,” all documents are unencrypted and readable by a privileged user session. From 2020 to 2025, five vulnerabilities allowing remote privileged access to MFTs were discovered and abused, resulting in major data breaches¹ [8, 23, 30].

These incidents underscore some of the challenges with the state of document encryption. Several file encryption methods exist to protect individual files, but each comes with major limitations. These methods include:

- 1) Password-based file encryption for each individual file is vulnerable to brute-force attacks [6, 9] and unauthorized sharing. It also has major usability issues such as the inability to recover or reset a forgotten password.
- 2) Proprietary solutions encrypt documents within a closed network. These solutions are typically paid for and locked into closed systems, limiting flexibility and accessibility for non-enterprise use cases.
- 3) Storage provider encryption (used by MFT apps, AWS S3 buckets, Dropbox, or Google Drive) only protects files “at rest.” Once someone gains access to the system, all files can be read and exfiltrated.

The combination of security, usability, and deployability challenges present in the document encryption methods available today prevents its adoption and effectiveness. There is a need for new methods and tools to address these challenges.

¹ Accellion Dec 2020, Serv-U Nov 2021, GoAnywhere Jan 2023, MOVEit May 2023, and Cleo Dec 2024

II. PURPOSE OF THE RESEARCH

The purpose of this research is twofold. First, to evaluate the security, usability, and deployability of existing document protection technologies to discover where they fall short of user needs. Second, to design a novel approach to document encryption utilizing the Open Trusted Data Format (OpenTDF) and open-source file encryption tools like age and Picocrypt to provide a file encryption that meets the following requirements:

- 1) Not password based, no memory needed
- 2) Not proprietary, meaning a) free, open-source b) when files are shared, the receiver doesn't need custom software to view or interact with the file
- 3) Individual document files are encrypted and not all accessible at once

III. REVIEW OF THE LITERATURE

Several efforts have been made by researchers to create simple and cost-effective methods of encrypting individual documents. The most common form of document encryption is password-based AES encryption which is built into Microsoft Word [32] and PDF processing software like Adobe Acrobat [33]. Typically, AES (128 or 256-bit) encryption is used with a single password as the key to protect the entire document. A major problem with this method (used by MS Word and most PDF documents) is that unlike a web-based password, once a password has been set to encrypt a document, it cannot be changed or recovered if forgotten [34]. One group of researchers discuss the potential implementation of new ciphers for PDF encryption, however the focus of their proposed solution is on minimizing the file size rather than improving the security and usability of the encryption features [3].

Several research efforts have demonstrated weaknesses with current file security measures. For example, in recent years, several vulnerabilities have been found in the rights management features for PDF [22] and Microsoft Office documents [7, 18]. Security researchers have also uncovered vulnerabilities in the digital signature process used to sign and verify PDF [15, 17], Microsoft Office (OOXML) [21], and OpenDocument [20] files. Novel attacks such as content masking [16] and modification of signed PDF files [15] have also been discovered and reported. Studies have found attacks that compromise the PDF 2.0 specification and impact nearly every PDF viewer software leading to much needed vendor security patches [22].

Some researchers have investigated the process for cracking the password of an encrypted PDF using GPUs [6] and tuned software [9]. This research found that nearly any password-based document encryption can be cracked with "little overhead" given enough time and the proper computational resources [6]. Results from prior research have also found methods to break XML encryption [10, 12]. The most recent and relevant research article on breaking PDF encryption emphasized that there are likely additional security flaws in document encryption, but limited research has been performed in the area [19].

Design research on document protection methods has primarily focused on maintaining privacy and integrity. For example, Crypt Pad is an open-source anonymous document editing software for which the design process has been analyzed [14]. Research to maintain offline document integrity resulted in a Microsoft Word plugin that tracks document changes and provides integrity and non-repudiation, but does not handle confidentiality [24]. Further related work has addressed serializing document encryption enforcement [26] and investigated a blockchain method [29] to protect documents.

Regarding the usability of encrypted documents, very little work has been done to directly assess the usability of current document protection methods. However, extensive usability research has been performed on passwords [1], passwordless technology [13], and encrypted email [4] which each presents important opportunities to address the problem of usability in document encryption.

Analysis of web authentication schemes has demonstrated the importance of considering deployability in addition to security and usability as many proposals to replace passwords have failed to gain traction due to a lack of real-world deployment considerations [1]. Deployability includes a low per-user cost to set up and operate a system. A highly deployable system is compatible with existing technology and can be implemented and used by anyone without having to pay a fee.

Several open-source tools present opportunities to address the existing challenges with document encryption. OpenTDF [35] is the open-source implementation of the Trusted Data Format which is a standard of the U.S. Director of National Intelligence [36] that enables attribute-based access control (ABAC) to be cryptographically tied to a data object. Picocrypt [31] and age [27] are lightweight, open-source file encryption tools with strong cryptographic features. Many modern devices now include a TPM (Trusted Platform Module) [37] which is a hardware-based security feature built into modern motherboards that can generate and store cryptographic keys. By utilizing a combination of these open source frameworks and encryption implementation there may be significant opportunities to improve file encryption methods to be secure, usable, and easily deployable.

IV. RESEARCH QUESTIONS

R1: What security, usability, and deployability limitations exist in current document protection technologies?

R2: How can open-source resources be leveraged to encrypt documents while minimizing the limitations of existing document protection methods?

V. METHODOLOGY OF THE RESEARCH

The methodology of this research will primarily be design-as-research with usability evaluations. First a systemization of knowledge for existing document protection methods will be performed using an analytical framework similar to those which have been used to evaluate password alternatives [1] and secure email [4]. This comparative analysis across existing methods will allow for a comprehensive identification of methods, their benefits, and weaknesses. Next, design requirements will be created based on the features and limitations of existing methods. Then, a novel design for document encryption using OpenTDF and open-source encryption tools like age and Picocrypt will be developed in accordance with the requirements. Based on the current literature review, it is expected that these three technologies (OpenTDF, age, Picocrypt) will be applied. However, final requirements will be determined by the steps described above. Finally, the solution will be evaluated by technical benchmarking, user acceptance testing (UTAUT), and usability testing (SUS) with human participants in a lab setting ($n \geq 20$).

SPECIFIC STEPS OF METHODOLOGY

1. Current Methods Assessment

Question to answer: What options currently exist for document protection?

- 1a. Find current document protection methods
- 1b. Develop an analytical framework (usability, security, deployability) to categorize document protection methods and evaluate their features and limitations
- 1c. Evaluate each method and record the rationale for its rating

2. Requirements for a Design Solution

Question to answer: What features should be present in a new “best-case” design?

Requirements will be created from the following sources:

- 2a. From Step 1, common features
- 2b. Analyzing real-world failures and use cases (e.g., MFT hacks)
- 2c. Existing research (including passwords and secure email adoption studies)
- 2d. Consulting experts

3. Design Solution

Design a solution based on the requirements (from step 2)

- 3a. Use OpenTDF locally with age or Picocrypt to encrypt document files (or other low-cost, viable method discovered in step 1).
- 3b. Store cryptographic keys in TPM (local), HSM (external), or hardware key (or other low-cost, viable method discovered in step 1).
- 3b. Design system to share documents (ideally by federated identity provider)
 - Build on Windows laptop, test on Linux, MacOS, Windows Server.
 - Focus on desktop use case (as opposed to mobile).

4. Assess Solution

Measure security, usability, deployability and user adoption of new solution.

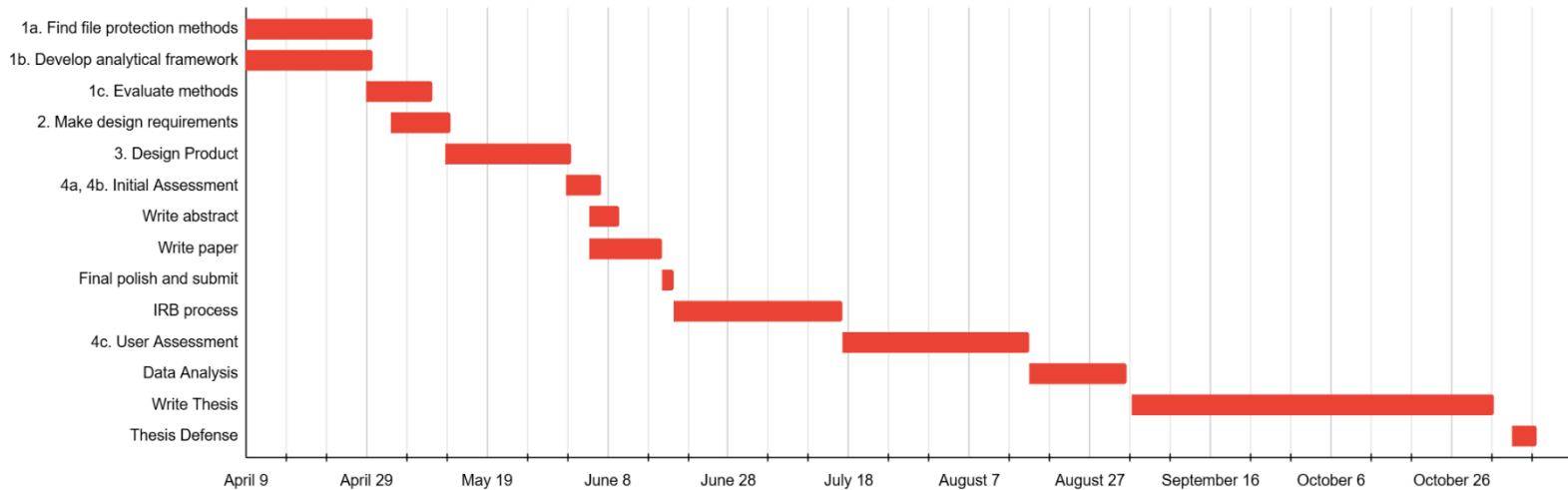
- 4a. Evaluate newly designed system on requirements (2) and framework (1b)²
- 4b. Technical security evaluation (run common attack scenarios discovered in 2b)
- 4c. User evaluation: usability and user acceptance testing
 - IRB approval
 - Usability tasks to assess include encrypting and sharing files with:
 - Word/PDF password-based method
 - New design
 - System Usability Scale (SUS) [2] for usability evaluation
 - UTAUT [28] for user acceptance evaluation
 - Record time on task
 - Open response text box for user participant comments describing the benefits and challenges of using the new solution.
 - Recruit participants from BYU peers and coworkers, without compensation, approximately $n \geq 20$.
 - Data Analysis: The SUS scale gives a single unit of measure. T-tests will be used as exploratory analysis to compare the time on task for the two systems. Cronbach's alpha will be used to ensure internal consistency of the UTAUT scale.

VI. COST OF THE RESEARCH

The study is not anticipated to have material costs as the resources are freely available (e.g. open-source software) or already owned by the researcher (e.g. computer).

² Deployability will be evaluated using the framework (1b) since the deployability benefits are objectively measurable without users. For example: Is it free to use? Is it open source? What is the cost to deploy this system? Is it compatible with major operating systems?

VII. TASKS AND TIMELINE



VIII. REFERENCES

- [1] Joseph Bonneau, Cormac Herley, Paul C. van Oorschot, and Frank Stajano. 2012. The Quest to Replace Passwords: A Framework for Comparative Evaluation of Web Authentication Schemes. In *2012 IEEE Symposium on Security and Privacy*, May 2012. 553–567. <https://doi.org/10.1109/SP.2012.44>
- [2] John Brooke. SUS - A quick and dirty usability scale.
- [3] Aastha Chauhan and Deepa Verma. 2024. Harnessing Lightweight Ciphers for PDF Encryption. <https://doi.org/10.48550/arXiv.2409.09428>
- [4] Jeremy Clark, P. C. Van Oorschot, Scott Ruoti, Kent Seamons, and Daniel Zappala. 2021. SoK: Securing Email—A Stakeholder-Based Analysis. In *Financial Cryptography and Data Security*, Nikita Borisov and Claudia Diaz (eds.). Springer Berlin Heidelberg, Berlin, Heidelberg, 360–390. https://doi.org/10.1007/978-3-662-64322-8_18
- [5] Caitlin Condon. 2023. Observed Exploitation of Critical MOVEit Transfer Vulnerability. *Rapid7*. Retrieved February 10, 2025 from <https://www.rapid7.com/blog/post/2023/06/01/rapid7-observed-exploitation-of-critical-moveit-transfer-vulnerability/>
- [6] Bianca Danczul, Jürgen Fuß, Stefan Gradinger, Bernhard Greslehner, Wolfgang Kastl, and Florian Wex. 2013. Cutforce Analyzer: A Distributed Brute-force Attack on PDF Encryption with GPUs and FPGAs. In *2013 International Conference on Availability, Reliability and Security*, September 2013. 720–725. <https://doi.org/10.1109/ARES.2013.94>
- [7] Martin Grothe, Christian Mainka, Paul Rösler, and Jörg Schwenk. 2016. How to break microsoft rights management services. In *Proceedings of the 10th USENIX Conference on Offensive Technologies (WOOT'16)*, August 08, 2016. USENIX Association, USA, 26–39.

- [8] John Hammond. 2025. Cleo Software Actively Being Exploited in the Wild. *Huntress Blog*. Retrieved April 9, 2025 from <https://www.huntress.com/blog/threat-advisory-oh-no-cleo-cleo-software-actively-being-exploited-in-the-wild>
- [9] Radek Hranický, Petr Matoušek, Ondřej Ryšavý, and Vladimír Veselý. 2024. Experimental Evaluation of Password Recovery in Encrypted Documents. November 14, 2024. 299–306. <https://doi.org/10.5220/0005685802990306>
- [10] Tibor Jager and Juraj Somorovsky. 2011. How to break XML encryption. In *Proceedings of the 18th ACM conference on Computer and communications security (CCS '11)*, October 17, 2011. Association for Computing Machinery, New York, NY, USA, 413–422. <https://doi.org/10.1145/2046707.2046756>
- [11] Bert Kondruss. MOVEit hack victim list | KonBriefing.com. Retrieved February 10, 2025 from <https://konbriefing.com/en-topics/cyber-attacks-moveit-victim-list.html>
- [12] Dennis Kupser, Christian Mainka, Jörg Schwenk, and Juraj Somorovsky. 2015. How to break XML encryption – automatically. In *Proceedings of the 9th USENIX Conference on Offensive Technologies (WOOT'15)*, August 10, 2015. USENIX Association, USA, 11.
- [13] Leona Lassak, Elleen Pan, Blase Ur, and Maximilian Golla. 2024. Why Aren't We Using Passkeys? Obstacles Companies Face Deploying {FIDO2} Passwordless Authentication. 2024. 7231–7248. Retrieved March 4, 2025 from <https://www.usenix.org/conference/usenixsecurity24/presentation/lassak>
- [14] Aaron MacSween, Caleb James Delisle, Paul Libbrecht, and Yann Flory. 2018. Private Document Editing with some Trust. In *Proceedings of the ACM Symposium on Document Engineering 2018 (DocEng '18)*, August 28, 2018. Association for Computing Machinery, New York, NY, USA, 1–10. <https://doi.org/10.1145/3209280.3209535>
- [15] Christian Mainka, Vladislav Mladenov, and Simon Rohlmann. 2021. Shadow Attacks: Hiding and Replacing Content in Signed PDFs. In *Proceedings 2021 Network and Distributed System Security Symposium*, 2021. Internet Society, Virtual. <https://doi.org/10.14722/ndss.2021.24117>
- [16] Ian Markwood, Dakun Shen, Yao Liu, and Zhuo Lu. 2017. {PDF} Mirage: Content Masking Attack Against {Information-Based} Online Services. 2017. 833–847. Retrieved January 22, 2025 from <https://www.usenix.org/conference/usenixsecurity17/technical-sessions/presentation/markwood>
- [17] Vladislav Mladenov, Christian Mainka, Karsten Meyer zu Selhausen, Martin Grothe, and Jörg Schwenk. 2019. 1 Trillion Dollar Refund: How To Spoof PDF Signatures. In *Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security (CCS '19)*, November 06, 2019. Association for Computing Machinery, New York, NY, USA, 1–14. <https://doi.org/10.1145/3319535.3339812>
- [18] Jens Müller, Fabian Ising, Christian Mainka, Vladislav Mladenov, Sebastian Schinzel, and Jörg Schwenk. 2020. Office Document Security and Privacy. 2020. . Retrieved January 22, 2025 from <https://www.usenix.org/conference/woot20/presentation/muller>
- [19] Jens Müller, Fabian Ising, Vladislav Mladenov, Christian Mainka, Sebastian Schinzel, and Jörg Schwenk. 2019. Practical Decryption exFiltration: Breaking PDF

- Encryption. In *Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security (CCS '19)*, November 06, 2019. Association for Computing Machinery, New York, NY, USA, 15–29.
<https://doi.org/10.1145/3319535.3354214>
- [20] Simon Rohlmann, Christian Mainka, Vladislav Mladenov, and Jörg Schwenk. 2022. Oops... Code Execution and Content Spoofing: The First Comprehensive Analysis of {OpenDocument} Signatures. 2022. 3075–3092. Retrieved January 22, 2025 from <https://www.usenix.org/conference/usenixsecurity22/presentation/rohlmann>
 - [21] Simon Rohlmann, Vladislav Mladenov, Christian Mainka, Daniel Hirschberger, and Jörg Schwenk. 2023. Every Signature is Broken: On the Insecurity of Microsoft {Office's} {OOXML} Signatures. 2023. 7411–7428. Retrieved January 22, 2025 from <https://www.usenix.org/conference/usenixsecurity23/presentation/rohlmann>
 - [22] Simon Rohlmann, Vladislav Mladenov, Christian Mainka, and Jörg Schwenk. 2021. Breaking the Specification: PDF Certification. In *2021 IEEE Symposium on Security and Privacy (SP)*, May 2021. 1485–1501.
<https://doi.org/10.1109/SP40001.2021.00110>
 - [23] Mathew J. Schwartz. 2023. Hackers Hit Secure File Transfer Software Again and Again. *Bank Info Security*. Retrieved April 9, 2025 from <https://www.bankinfosecurity.com/blogs/hackers-hit-secure-file-transfer-software-again-again-p-3529>
 - [24] Ahmed Shatnawi, Ethan V. Munson, and Cheng Thao. 2017. Maintaining Integrity and Non-Repudiation in Secure Offline Documents. In *Proceedings of the 2017 ACM Symposium on Document Engineering (DocEng '17)*, August 31, 2017. Association for Computing Machinery, New York, NY, USA, 59–62.
<https://doi.org/10.1145/3103010.3121038>
 - [25] Zach Simas. 2023. Unpacking the MOVEit Breach: Statistics and Analysis. *Emsisoft | Cybersecurity Blog*. Retrieved April 9, 2025 from <https://www.emsisoft.com/en/blog/44123/unpacking-the-moveit-breach-statistics-and-analysis/>
 - [26] Margaret Sturgill and Steven J. Simske. 2016. Mass Serialization Method for Document Encryption Policy Enforcement. In *Proceedings of the 2016 ACM Symposium on Document Engineering (DocEng '16)*, September 13, 2016. Association for Computing Machinery, New York, NY, USA, 193–196.
<https://doi.org/10.1145/2960811.2967166>
 - [27] Filippo Valsorda. 2025. FiloSottile/age. Retrieved April 9, 2025 from <https://github.com/FiloSottile/age>
 - [28] Venkatesh, Morris, Davis, and Davis. 2003. User Acceptance of Information Technology: Toward a Unified View. *MIS Quarterly* 27, 3 (2003), 425.
<https://doi.org/10.2307/30036540>
 - [29] Chao Yuan, Mixue Xu, Xueming Si, and Bin Li. 2017. Blockchain with Accountable CP-ABE: How to Effectively Protect the Electronic Documents. In *2017 IEEE 23rd International Conference on Parallel and Distributed Systems (ICPADS)*, December 2017. 800–803. <https://doi.org/10.1109/ICPADS.2017.00111>
 - [30] 2023. #StopRansomware: CL0P Ransomware Gang Exploits CVE-2023-34362 MOVEit Vulnerability | CISA. Retrieved April 9, 2025 from <https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-158a>

- [31] 2025. Picocrypt/Picocrypt. Retrieved April 9, 2025 from <https://github.com/Picocrypt/Picocrypt>
- [32] Protect a document with a password - Microsoft Support. Retrieved April 9, 2025 from <https://support.microsoft.com/en-us/office/protect-a-document-with-a-password-05084cc3-300d-4c1a-8416-38d3e37d6826>
- [33] Securing PDFs with passwords. Retrieved April 9, 2025 from <https://helpx.adobe.com/content/help/en/acrobat/using/securing-pdfs-passwords.html>
- [34] You cannot recover a document that is protected with a password if the password is lost in Word - Microsoft Support. Retrieved April 9, 2025 from <https://support.microsoft.com/en-us/topic/you-cannot-recover-a-document-that-is-protected-with-a-password-if-the-password-is-lost-in-word-65a1f34b-fa3f-665a-4913-7ecbb8e01f5f>
- [35] OpenTDF. *GitHub*. Retrieved April 9, 2025 from <https://github.com/opentdf>
- [36] Trusted Data Format. Retrieved April 15, 2025 from <https://www.dni.gov/index.php/who-we-are/organizations/ic-cio/ic-technical-specifications/trusted-data-format>
- [37] ISO/IEC 11889-1:2015. *ISO*. Retrieved April 9, 2025 from <https://www.iso.org/standard/66510.html>